ITA CHALLENGE SPRINT · SEMANA 2 · HIPÓTESE DE SOLUÇÃO

GerencIA: rastrear a informação que entra na IA, e provar o risco.

Como a solução em desenvolvimento atende aos requisitos do Desafio 2 (Stark Bank): o funcionamento, o papel da IA, a linha de base contra a qual mediremos, a métrica e a meta, e os dados.

Base oficial: 650 eventos · 160 alertas · 8 ferramentas · 20 tipos de informação · 72 usuários · 14 regras · dados fictícios (declarado na planilha)

Funcionamento

Uma frase, depois o mecanismo

GerencIA rastreia a informação, não o clique. Em vez de "o usuário X abriu o ChatGPT às 14h", ela responde "a chave/API secret apareceu em 5 ferramentas, com 30 pessoas, 35 vezes — 3 em IA pública", reaplica a política de risco com cadeia de evidência e audita a própria rotulagem existente.

O mecanismo tem quatro movimentos:

- **Capturar na borda.** Três camadas complementares observam o uso de IA na estação do usuário e mandam o registro a um coletor central on-premise.
- **Resolver a identidade no sistema operacional.** Quem usou é o usuário logado na máquina — nunca decidido pela página.
- **Reaplicar a política com IA.** Um motor classifica a informação, decide o risco por precedência de regras e monta a cadeia de evidência; o que a regra não resolve sobe para uma LLM, que devolve aprendizado.
- **Unificar e investigar.** A planilha (legado) e as capturas ao vivo (presente) entram na mesma base e no mesmo motor; o painel dá busca reversa, alertas e indicadores recalculados.

O desenho

Arquitetura da solução

CAPTURA · BORDA

Extensão de navegador

Vê o **conteúdo** (prompt + resposta). Detectores e fingerprint rodam local.

CAPTURA · BORDA

Agente / serviço

Metadado de uso de IA em qualquer app. Sobe no boot, identifica o usuário logado.

CAPTURA · OPCIONAL

Proxy TLS (MITM)

Conteúdo de qualquer app, via interceptação corporativa. Só com aval de Segurança.

↓

Coletor central (on-premise)

Recebe as capturas, **resolve a identidade no SO** (usuário logado), grava a trilha em banco sob controle da empresa e regenera o painel.

↓

Motor de IA — classifica, decide o risco, audita

IA clássica (núcleo)

Detectores (CPF/CNPJ/Luhn/credencial) + fingerprint (MinHash/SimHash) + regras R01–R14 com **precedência** → risco + cadeia de evidência.

cascata ⇄ aprendizado

LLM (quando a regra não basta)

Linguagem natural no rastreio e na classificação; o que ela resolve **vira padrão** de volta para a IA clássica.

↓

Base unificada

Excel = **legado** · capturas ao vivo = **presente**. Mesma tabela, mesmo motor, distinguidos pela origem.

↓

Painel de governança

Investigação e prova para Compliance e Segurança.

`Panorama` `Rastrear (busca reversa)` `Alertas + evidência` `Auditoria` `Validação` `Política` `Inventário` `Captura`

Papel da IA

A IA é o núcleo — e é auditável

A IA **não é apoio**: as três decisões centrais da solução são feitas por IA — **classificar** a informação, **decidir** o risco e **rastrear** em linguagem natural. O que a torna aceitável em Compliance é que ela é **auditável**: decide por regras explícitas com precedência e devolve a cadeia de evidência, não uma caixa-preta.

`IA clássica · decide`

Classificação e risco

Detectores validam CPF/CNPJ (dígito), cartão (Luhn) e credenciais; o fingerprint reconhece trechos de documentos do acervo; as regras R01–R14 dão o nível por precedência declarada. Determinística e explicável.

`LLM · quando a regra falha`

Linguagem natural + aprendizado

Entra em cascata quando a IA clássica não resolve — entende sinônimo e paráfrase no rastreio e na classificação. O que resolve volta como padrão para a IA clássica, reduzindo o custo de LLM ao longo do tempo.

Por que usar IA (e não só consulta manual)

- **Volume e continuidade:** centenas de eventos na base e um fluxo ao vivo que cresce — reavaliar à mão é inviável.
- **Linguagem natural:** a pergunta do auditor (“onde vazou dado de cliente?”) e o conteúdo dos prompts não são chaves exatas; exigem compreensão.
- **Consistência auditável:** a política escrita em texto precisa ser aplicada sempre da mesma forma, com a evidência do porquê — é o que a IA clássica garante.

`Requisitos`

Como a solução atende ao desafio

Requisito do desafio	Onde a solução entrega
Registrar quais ferramentas de IA são usadas	Vista **Inventário** + aba Ferramentas_IA + captura ao vivo
Identificar quais informações são compartilhadas	Vista **Rastrear** (busca reversa) + fingerprint
Classificar por sensibilidade	Detectores + tipos de informação + vista **Política**
Usuário, área, ferramenta, data e finalidade	Esquema de eventos, todas as colunas; identidade resolvida no SO
Histórico que permita rastrear o fluxo	Linhagem da informação + trilha em banco
Identificar situações de risco e gerar alertas	Motor R01–R14 + vista **Alertas** com cadeia de evidência

Requisito do desafio	Onde a solução entrega
Filtros (área, usuário, ferramenta, tipo, risco, período)	Filtros compartilhados no painel
Indicadores de acompanhamento	Vista **Auditoria** — recalculados, não repetidos
Apoiar auditorias e investigações com evidência	Cadeia de regras aplicáveis, com motivo e ação, por evento
A empresa define classificações e regras	Tudo lido da planilha; o código não reescreve as regras

Linha de base · métrica · meta

O que mediremos, e contra o quê

Resultado atual do processo (linha de base)

Hoje a governança se apoia em indicadores **declarados** que não batem com a realidade da própria base:

7 / 10
indicadores declarados divergem do apurado

6,8% → 16,6%
eventos críticos: subnotificação de ~2,4×

72% → ?
SLA de alerta em 24h: declarado, mas **não apurável**

Somam-se seis achados de auditoria — entre eles 38 eventos cuja regra citada engana o auditor, 18 em que a obrigação de LGPD some do registro, e 6 das 14 regras que nunca disparam. E rastrear uma informação, hoje, é manual.

Métrica de sucesso e meta a testar

Métrica	Base	Meta (Sprint)
Fidelidade da governança (indicadores declarado × real)	7/10 divergem	**0/10 divergem** após adoção
Reprodução do gabarito oficial	—	**15/15** casos (atingido)
Concordância de nível de risco com a base	—	**≥ 98%** (98,8% atingido)
Alertas com cadeia de evidência íntegra	38 enganam	**100%** auditáveis
Tempo para rastrear uma informação (linhagem)	manual	**< 5 s** na busca reversa

A métrica primária do Sprint é a **fidelidade da governança**: fechar as sete divergências entre o que a empresa declara e o que a base mostra.

Dados

Disponíveis e com qualidade medida

Disponível · legado

Base oficial do desafio

650 eventos, 160 alertas, 8 ferramentas, 20 tipos de informação, 72 usuários, 14 regras, em 12 abas. Fictícios, conforme declarado. Classificação já vem pronta (origem “Classificador/DLP”).

Disponível · presente

Capturas ao vivo

Extensão, agente e (opcional) proxy alimentam o mesmo banco, com identidade resolvida no SO e origem marcada (extensão / agente / proxy).

Qualidade — e por que ela é parte do problema

O dado existe, mas a solução **não confia nele cegamente**: ao reaplicar as regras, ela mede a qualidade da rotulagem e encontra os defeitos — rótulos que induzem o auditor a erro, ausência de data de tratamento (que torna o SLA não apurável), regras genéricas no lugar das específicas. Medir a qualidade do dado é, aqui, um entregável, não um pré-requisito.

As 6 perguntas da Semana 2

Respondidas, uma a uma

01

Como a solução atende aos requisitos?

Atende ao reenquadrar o problema de “registrar uso” para “rastrear informação”. Cada requisito do desafio tem um lugar concreto na solução (tabela acima): o inventário lista as ferramentas, a busca reversa identifica a informação compartilhada, os detectores classificam a sensibilidade, o esquema de eventos guarda usuário/área/ferramenta/data/finalidade, a linhagem dá o histórico, o motor R01–R14 identifica risco e gera alertas com evidência, os filtros cruzam as dimensões e a vista Auditoria recalcula os indicadores. E o principal: as regras e classificações são as da empresa (lidas da planilha), não reescritas pelo código.

02

Qual valor ela entrega?

Entrega **confiança na governança**. Antes, a decisão de risco se apoiava em indicadores que erram por até 2,4×; a solução devolve indicadores apurados, com evidência verificável célula a célula. Entrega **linhagem da informação** — poder partir de um documento sensível e ver toda a sua trajetória por ferramentas e pessoas, que é exatamente a pergunta norteadora do desafio. E entrega **auditabilidade**: cada alerta vem com o porquê e a ação obrigatória, o que faz uma auditoria de LGPD fechar. Em uma linha: transforma “achamos que estamos seguros” em “conseguimos provar onde não estamos”.

03

Qual tarefa a IA executa e por que usá-la?

A IA executa três tarefas: **(1) classificar** o conteúdo (tipo de informação e sensibilidade) com detectores e fingerprint; **(2) decidir** o nível de risco aplicando as 14 regras por ordem de precedência, com a cadeia de evidência; e **(3) rastrear** em linguagem natural, quando a busca literal não basta, com uma LLM em cascata que devolve aprendizado à IA clássica. Usa-se IA porque o volume e o fluxo contínuo inviabilizam a análise manual, porque tanto o rastreio quanto a classificação lidam com linguagem natural (sinônimo, paráfrase), e porque a política precisa ser reaplicada de forma consistente e explicável — que é o que a IA clássica garante e a LLM complementa sem virar caixa-preta.

04

Qual é o resultado atual?

O processo atual produz um painel de governança cujos números **não se sustentam**: 7 dos 10 indicadores declarados divergem do que a base mostra; os eventos críticos são subnotificados de 6,8% para 16,6% reais; o SLA de tratamento em 24h é declarado em 72% mas não é apurável (não há data de tratamento); e 6 das 14 regras nunca são acionadas, dando falsa sensação de cobertura. Rastrear uma informação específica pela cadeia de ferramentas e pessoas, hoje, não é um recurso disponível — é trabalho manual. É essa a linha de base que a solução se propõe a superar.

05

Qual métrica e qual meta serão testadas?

A métrica primária é a **fidelidade da governança** — a distância entre o indicador declarado e o apurado — com meta de **zerar as 7 divergências**. Como métricas de corretude do motor, testamos a reprodução do **gabarito oficial (meta 15/15, já atingida)** e a **concordância de nível de risco com a base (meta ≥ 98%, hoje 98,8%)**. Para o valor de auditoria, medimos a fração de **alertas com cadeia de evidência íntegra (meta 100%)** e o **tempo de rastreamento de uma informação (meta < 5 s)**. São métricas verificáveis contra a própria base oficial, não afirmações.

06

Quais dados estão disponíveis?

Dois conjuntos. O **legado**: a base oficial do desafio — 650 eventos, 160 alertas, 8 ferramentas, 20 tipos de informação, 72 usuários e 14 regras, em 12 abas, com a classificação já preenchida (origem Classificador/DLP) e dados fictícios declarados. E o **presente**: as capturas ao vivo da borda (extensão, agente e, opcionalmente, o proxy), com identidade resolvida no sistema operacional. Sobre a qualidade: o dado está disponível, mas a solução o audita — e é justamente medindo a qualidade da rotulagem que ela encontra os seis achados. Medir a qualidade do dado é um entregável do projeto.

Critério da Semana 2

Coerência da solução e proposta de valor

01

Atendimento aos requisitos

Cada requisito do desafio mapeado a uma vista/mecanismo concreto; regras e classificações são as da empresa.

02

Papel da IA

IA é o núcleo (classifica, decide, rastreia), auditável por regras e evidência; LLM em cascata com aprendizado.

03

Linha de base, métrica e meta

Base honesta (7/10 divergem, críticos 2,4× subnotificados); métrica de fidelidade com meta de zerar divergências.

04

Dados disponíveis e qualidade

Legado + presente, com a qualidade da rotulagem medida pela própria solução (os seis achados).
